

eKYC Platform: Production Review and Product Strategy

PREPARED FOR	Malcolm, Move Digital
DATE	2 September 2026
SCOPE	MalcolmGov/ekyc at commit 6595ce1 , with MalcolmGov/aria (Zara agent marketplace) reviewed as the integration target
STATUS	Planning document. No code has been changed in either repository.

CONTENTS

- [1. Verdict](#)
[2. What was reviewed and how](#)
[3. What the repository actually is today](#)
[4. Findings](#)
[5. What you are actually selling](#)
[6. Target architecture](#)
[7. Extending into the Zara agent marketplace](#)
- [8. Compliance and regulatory requirements](#)
[9. Roadmap](#)
[10. Definition of production ready](#)
[11. Decisions needed from you](#)
[Appendix A: route inventory and authentication state](#)
[Appendix B: build and audit output](#)

1. Verdict

The ekyc repository is not production grade and should not be offered to clients in its current state. It is a well-presented prototype: the UI is broad and the stack is sensible, but the verification engine behind it is largely simulated, the API has almost no authentication, passwords are

stored in plain text, and results can be forged by anyone who can reach the server.

The `PRODUCTION-READINESS.md` file in the repo says "PRODUCTION READY, zero additional development required". That document is not accurate. Of the twenty-one "production ready" claims it makes, the code supports four (multi-country list, Didit session creation, PWA shell, multi-language UI). The rest are either simulated, marketing copy, or contradicted by the code.

The good news is that the product idea is sound and the market position is real. The repo is best treated as a **functional specification and UI prototype** for a new build, not as a codebase to patch. Roughly 60% of the server needs to be rewritten; most of the client can be kept.

Recommended path: rebuild the server as a multi-tenant "Verification Core" API (Section 7), ship a hardened KYC-only pilot first, add real KYB in a second phase, then package both as Zara marketplace agents (Section 8). A pilot-safe KYC product is realistic in six to eight weeks of focused engineering. A sellable KYC + KYB + onboarding product is a five to six month programme.

2. What was reviewed and how

- Full read of `server/` (5,300 lines), `shared/schema.ts`, client hooks, API client, routing, and all deployment config.
- Install, typecheck (`npm run check`) and dependency audit run against a fresh clone.
- Every HTTP route catalogued with its authentication state (Appendix A).
- `aria` reviewed for the agent package format, catalogue and suite model, the webhook and MCP integration rails, and the runtime sidecar, so the marketplace plan is grounded in what actually exists there.

I could not test against live Didit or Twilio credentials, so vendor behaviour is assessed from the code and the vendors' published contracts, not from live calls.

3. What the repository actually is today

CAPABILITY THE REPO PRESENTS	WHAT THE CODE DOES	STATUS
Identity verification (document, liveness, face match) via Didit	Creates a Didit session when real credentials are present. On any failure it silently returns a fabricated "demo" session. Webhook status updates never persist because of a lookup bug.	Partially real, unreliable
Business verification (KYB) with registry, AML, UBO and sanctions checks	No registry, AML or sanctions call is made anywhere. A regex checks the registration number format, then a function named <code>performIntelligentBusinessVerification</code> produces an "approved" status, a risk score and AML results. The Ballerine endpoint it tries first does not exist as coded.	Simulated
Uganda KYB onboarding with document upload	Applications and uploaded ID documents are held in a JavaScript <code>Map</code> in process memory. Everything is lost on restart. Approval endpoint is unauthenticated.	Demo only
WhatsApp verification links via Twilio	Works when Twilio is configured. The send endpoint is unauthenticated, so anyone can send messages from your Twilio account to any number.	Real, exposed
Compliance dashboard with PII masking and audit trail	Masking exists for individual sessions only. The "audit log" is <code>console.log</code> with a hardcoded user of <code>system_user</code> . Business sessions (directors, UBOs, AML results) are returned unmasked and unauthenticated.	Cosmetic
Role-based access control	One middleware (<code>requireAdmin</code>) protects one route. Every other write	Cosmetic

CAPABILITY THE REPO PRESENTS	WHAT THE CODE DOES	STATUS
	endpoint is open.	
Developer API, SDKs, API keys	Marketing pages describe <code>npm install @swifterid/sdk , sk_live_</code> keys and <code>dashboard.swifterid.com</code> . None of these exist. There is no API key model or tenant model in the schema.	Marketing only
54 African countries supported	A seeded table of 54 country rows with the same two document types each. Country support in a KYC product means vendor coverage per document type, which is not modelled.	List only
Multi-language (15 languages), PWA, mobile-first UI	Present in the client.	Real
Analytics dashboard	Real queries over the sessions table. Currently populated with 50 randomly generated sample sessions in development.	Real, thin

4. Findings

Severity is judged by what happens if a paying client is put on this system today. File references point at the reviewed commit.

Critical: blocks any client use

C1 Passwords are stored and compared in plain text.

`server/storage.ts:76` compares `user.password === password` . Any database read exposes every credential. There is no registration route, so users are created by hand in the database.

C2 Verification results can be forged by anyone. `POST /api/webhook/didit` (`server/routes.ts:1431`) accepts `{session_id, status: "completed"}` from any caller with no signature check and writes it to the session. The compliance dashboard will then show that person as verified. `PATCH /api/verification-sessions/:id` (`routes.ts:1391`), `PATCH /api/business-verification/sessions/:id` (`routes.ts:1827`) and `PATCH /api/kyb/uganda/applications/:id/status` (`routes/ugandaKYB.ts:285`) are also unauthenticated and allow arbitrary status changes including approval.

C3 The signed webhook can be bypassed with a header. The "secure" webhook at `/api/webhooks/didit` skips signature verification when the request carries `x-demo-mode: true` (`routes.ts:549`). The webhook secret also has a hardcoded fallback value committed in source (`routes.ts:18`).

C4 Personal data is readable without authentication. Full business verification records including directors, shareholders, beneficial owners and AML results (`GET /api/business-verification/sessions` , `routes.ts:1852`); Uganda applicant names, phone numbers and districts (`routes/ugandaKYB.ts:250`); WhatsApp session records with phone number, IP address and user agent (`routes.ts:2422`); the full analytics export (`routes.ts:1310`); and the list of live test-access tokens (`server/index.ts:137`).

C5 The system fabricates verification outcomes when vendors fail. When Didit session creation fails, the API returns a demo session rather than an error (`routes.ts:190` to `routes.ts:520` , including leftover debug code `if (false && MOCK_MODE || ...)`). KYB "completion" (`routes.ts:2170`) catches any vendor error and falls through to the simulation, then records `status: completed` , a risk score and clean AML results. A client would have no way to distinguish a real approval from a simulated one.

C6 Outbound messaging is open to abuse. `POST /api/whatsapp/create-verification-link` (`routes.ts:2265`) is unauthenticated. Anyone can drive Twilio spend and send branded WhatsApp messages to arbitrary numbers.

C7 Secrets and access artefacts are committed. `.test-tokens.json` contains live test-access tokens with names and email addresses. `new_cookies.txt` contains a session cookie. Docs contain the Twilio Account SID,

Meta Business Manager IDs and message SIDs. On production start the server creates two new test tokens automatically (`server/index.ts:85`).

High: must be fixed before a pilot

H1 Didit webhook updates never persist. The handler looks the session up correctly, then calls `updateVerificationSession(session.id.toString(), ...)` with the numeric id where the string session id is expected (`routes.ts:584`). The update matches nothing, and the code logs success anyway. Real verifications will sit at `pending forever`.

H2 Session security. `cookie.secure` is `false` , the session secret defaults to `dev-secret-change-in-production` , and the default in-memory session store is used despite `connect-pg-simple` being installed (`server/index.ts:20`).

H3 Security middleware is installed but not wired. `helmet` , `cors` , `express-rate-limit` and `compression` are dependencies and none is used. The global error handler responds and then rethrows (`server/index.ts:185`).

H4 Uploaded identity documents are held in memory. `routes/ugandaKYB.ts:76` . No object storage, no encryption, no retention, lost on restart.

H5 No tenancy, API keys or customer model. The schema has `users` , `verification_sessions` , `countries` , `business_verification_sessions` and `whatsapp_verification_sessions` . Nothing links a session to a paying customer. You cannot onboard a second client without them seeing the first client's data.

H6 Engineering baseline is missing. `npm run check` fails with 13 type errors. There are no tests, no CI, no linter and no migrations (schema is applied with `drizzle-kit push`). `npm audit` on production dependencies reports 36 vulnerabilities: 1 critical, 21 high, 12 moderate, 2 low.

H7 Deployment is tied to Replit. Callback URLs are built from `REPLIT_DOMAINS` , `ekyc-africa.com` is hardcoded in eleven places, `vercel.json` deploys the frontend only (the API is excluded), and there is no Dockerfile.

H8 Compliance claims are not backed by the code. No audit table, no consent capture, no retention or deletion, raw vendor payloads stored in `vendor_data` JSON, no per-tenant isolation, biometric processing and cross-border transfer not addressed (see Section 9).

Medium: should be fixed in the rebuild

- Two definitions of `GET /api/stats` (`routes.ts:1139` and `routes.ts:1736`); the second is unreachable.
- Session creation tries three different authentication schemes against Didit in sequence rather than using the documented one.
- Webhook handler loads every session into memory to find one.
- UBO threshold hardcoded at 25% (`routes.ts:1985`); South Africa's beneficial ownership register uses 5%.
- Brand inconsistency across pages: eKYC Africa, SwifterID and Move Digital.
- Repository hygiene: roughly 200 screenshots, nine pitch decks and a 700 KB app export in the tree; `attached_assets/` is served publicly by the API.

What is worth keeping

- The stack: TypeScript end to end, React, Express, Drizzle, PostgreSQL. Nothing exotic, easy to hire for.
- Didit as the primary document and biometric vendor. Hosted flow, webhook model and free tier suit an African SME product.
- The WhatsApp link pattern: a link sent to the applicant that opens a hosted verification flow. This is the right channel for the market and maps directly onto how Zara agents hand off.
- The KYB data model shape: business, directors, shareholders, UBOs, documents, risk score, compliance status. The fields are right even though nothing fills them honestly.
- The country registration-number patterns and the data masking utility are usable starting points.
- Most of the client: 26 pages, component library, i18n, PWA shell. It will need rewiring to a new API and a single brand.

5. What you are actually selling

Before designing the rebuild, the three product lines need precise definitions, because "agent" means something different in each.

PRODUCT	WHAT THE CLIENT GETS	WHAT THE "AGENT" DOES	WHAT IT MUST NEVER DO
KYC Agent	Individual identity verification for their customers: document, liveness, face match, optional government database check, sanctions and PEP screening, a decision and an evidence pack	Talks to the applicant on WhatsApp or web, explains what is needed, sends the secure verification link, follows up on drop-off, answers questions, and reports the outcome to the client's system	Collect ID numbers, selfies or documents in the chat itself. Verification always happens in the hosted, audited flow.
KYB Agent	Business verification: registry lookup, director and UBO identification, KYC of each UBO, sanctions and adverse media, a risk rating, and a case file a compliance officer can defend	Collects business details conversationally, runs the checks through the core, KYCs the directors via links, chases missing documents, and prepares the case for human decision	Approve on its own. KYB decisions carry human accountability and the agent's output is a recommendation with evidence.

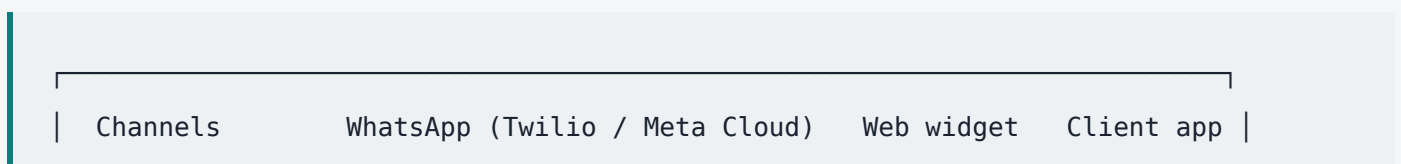
PRODUCT	WHAT THE CLIENT GETS	WHAT THE "AGENT" DOES	WHAT IT MUST NEVER DO
Digital Onboarding Flows	A configurable, white-labelled onboarding journey for the client's customers: form steps, KYC, KYB, agreements, and a webhook back into their systems on completion	Optional. A flow can run with or without an agent in front of it.	Run without a flow definition owned by the client.

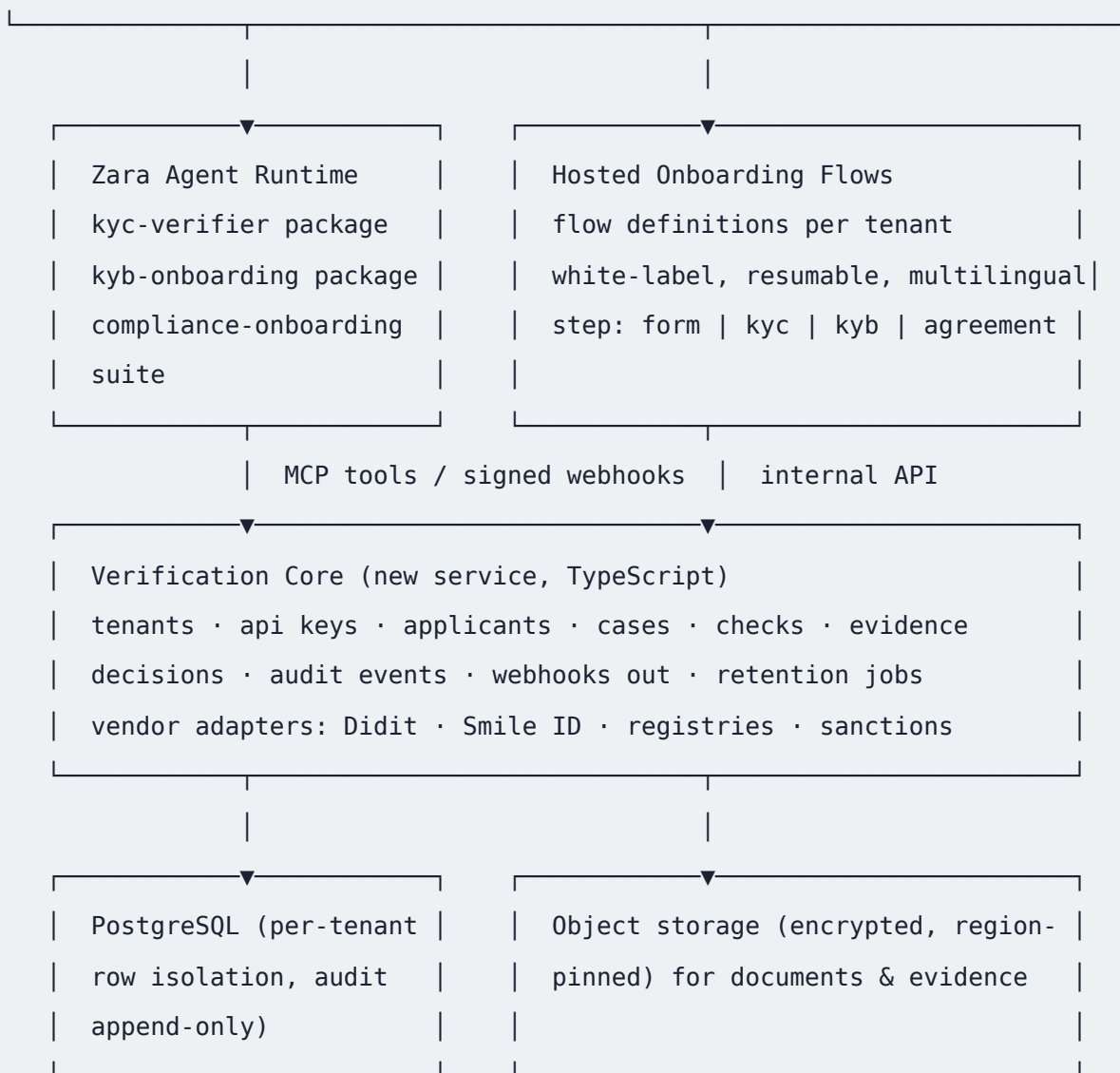
Two design rules fall out of this:

1. **The verification engine and the agent are separate products.** The engine is an API with an audit trail. The agent is a Zara package that calls it. Clients who want no agent still buy the engine.
2. **Agents orchestrate; they do not verify.** This is also how the existing Zara packages are written: the onboarding-buddy workflow "never collects banking/card in chat", and the loan pre-qualifier returns indicative results, "never a credit decision". KYC and KYB agents must hold the same line or the compliance story collapses.

First customers are already in the group. Gaslite needs verified drivers. Zara needs verified retail partners. Both are honest pilots that exercise the KYC flow, the WhatsApp channel and the webhook-out integration before an external client depends on them.

6. Target architecture





6.1 Verification Core

A new Express or Fastify service in TypeScript, replacing `server/`. Keep Drizzle and PostgreSQL. Key changes from today:

- **Tenancy.** Every table carries `tenant_id`. API keys are hashed, scoped and rotatable. A tenant's staff log in with hashed passwords (argon2) and roles: owner, compliance officer, agent operator, read-only.
- **Case model instead of session model.** An `applicant` (person or business) has `cases`; a case has ordered `checks` (document, liveness, face match, registry, sanctions, PEP, adverse media, UBO discovery); each check has `evidence` (vendor payload reference, document pointer, screenshot) and a `result`. A case ends in a `decision` with a named decider (system or user) and a reason.

- **Vendor adapters behind one interface.** IdentityVendor (Didit first, Smile ID second), RegistryVendor (per country), ScreeningVendor (sanctions and PEP). Every adapter returns a typed result or throws. No adapter may return a simulated success. Sandbox mode is a tenant setting that is visible on every record it touches.
- **Webhooks in and out.** Inbound vendor webhooks verified on raw bytes, idempotent on vendor event id, processed by a queue. Outbound webhooks to the client's system signed with HMAC and retried, matching the envelope format Zara already documents so one integration guide serves both.
- **Audit and retention.** Append-only audit_events table (who, what, which record, when, from where). Retention policy per tenant with scheduled deletion and a deletion certificate. Vendor payloads stored as encrypted evidence objects, not inline JSON.
- **Operational baseline.** Dockerfile, migrations, health and readiness endpoints, structured logs with request ids, rate limiting, helmet, CORS allowlist, secrets from environment only, CI running typecheck, lint, tests and audit on every push.

6.2 Vendor strategy

NEED	RECOMMENDED	WHY	NOTE
Document, liveness, face match	Didit (keep)	Hosted flow, webhooks, broad document coverage, free tier for early volume	Use the current v2 session API with x-api-key ; drop the three-way auth guessing
African government database checks (SA DHA, Nigeria NIN/BVN, Kenya IPRS, Ghana NIA)	Smile ID as second adapter	Direct government checks are where African KYC differentiates; Didit's coverage here is weaker	Contractual and per-check cost; enable per tenant

NEED	RECOMMENDED	WHY	NOTE
Sanctions, PEP, adverse media	Didit AML screening for pilot; evaluate OpenSanctions (commercial licence) or ComplyAdvantage for KYB	Keeps one vendor for the pilot; KYB needs entity-level screening later	
Company registries	Adapter per country. Start with South Africa (CIPC data via an accredited data partner), then Kenya BRS, Nigeria CAC, Ghana ORC, Uganda URSB	Direct API access differs by country and often requires an agreement	Every registry adapter needs a manual review fallback : an operator uploads the registry extract and attests. Honest assisted KYB beats fake automated KYB
Workflow engine (Ballerine)	Drop the fictitious API call. Either self-host Ballerine properly or, more simply, implement the case state machine in the core	The current integration is against an endpoint that does not exist	Own state machine recommended; Ballerine can be revisited at scale
WhatsApp	Keep Twilio for the pilot; plan the move to Meta WhatsApp Cloud API that Zara already runs	Zara has the templates, the handover doc and the number	

6.3 Hosted Onboarding Flows

A `flow_definitions` table per tenant: an ordered list of steps with types `form`, `kyc`, `kyb`, `document`, `agreement`, `review`, `webhook`. A `flow_runs` table tracks an applicant through a definition and is resumable from a link. The existing client pages (`verify`, `kyb`, `whatsapp-verify`, `verification-success`) become the renderers for these steps under the tenant's branding. This is what "Digital

Onboarding flows for business customers" means concretely: a client configures a definition, gets a link or a widget, and receives a signed webhook when a run completes.

7. Extending into the Zara agent marketplace

Zara already has the machinery this needs: a `zara.agent-package/v1` format with manifest, system prompt, knowledge, typed tools with `side_effects` and `auth_scope` , guardrails and evals; a catalogue of 500 SKUs across five markets; suites that bundle families; a runtime sidecar; and two integration rails (signed webhooks and MCP) documented at `docs/marketplace/CONNECT_YOUR_BACKEND.md` . There is no KYC or KYB family in the catalogue today, and the adjacent families (`onboarding-buddy` , `loan-prequalifier` , `sim-registration` , `policy-compliance` , `fraud-investigations`) all follow the "collect, explain, hand off, never decide" pattern.

7.1 New families

FAMILY ID	NAME	TIER	CHANNELS	WHAT IT DOES
<code>kyc-verifier</code>	Identity Verification Agent	pro	whatsapp, web, app	Explains what is needed, sends the secure verification link, tracks status, nudges on drop-off, answers document questions, reports outcome
<code>kyb-onboarding</code>	Business Onboarding Agent	enterprise	whatsapp, web	Collects business identity conversationally, triggers registry and screening checks, sends KYC links to each director and UBO, chases documents, hands a prepared case to a human

Both are built for the `africa` market first with `en`, `zu`, `af`, `fr`, `sw` in the manifest, and `compliance: ["popia", "fica"]`.

7.2 A compliance-onboarding suite

One entry in `agent_platform/suites.py`, no schema change: `kyc-verifier`, `kyb-onboarding`, `onboarding-buddy`, `policy-compliance`, `fraud-investigations`. Sector: "Banks, lenders, insurers, fintech and any regulated onboarding". This gives the marketplace a compliance vertical that mirrors the insurance-ops suite shipped in August.

7.3 Tools

The Verification Core exposes an MCP server (Zara already ships `agent_platform/mcp_server.py` and `movedigital_mcp.py`, so the pattern exists). Tool definitions follow the loan pre-qualifier package's discipline:

TOOL	SIDE_EFFECTS	PURPOSE
<code>explain_requirements(country, document_type?)</code>	read-only	Authoritative checklist for the applicant's country
<code>start_kyc(applicant_ref, channel, language)</code>	write	Creates a case in the core and returns the hosted link. Never accepts identity data as arguments.
<code>get_case_status(case_ref)</code>	read-only	Status and next action, no PII in the response

T00L	SIDE_EFFECTS	PURPOSE
<code>start_kyb(business_name, registration_number, country)</code>	write	Opens a business case and kicks off registry lookup
<code>add_related_person(case_ref, role, contact)</code>	write	Registers a director or UBO and triggers their KYC link
<code>request_document(case_ref, document_type)</code>	write	Adds an outstanding document request and returns an upload link
<code>escalate(case_ref, reason)</code>	write	Hands off to the tenant's compliance desk

7.4 Guardrails and evals

- The agent never asks for, acknowledges or stores an ID number, date of birth, selfie or document image in chat. If a user sends one, the agent does not repeat it back and redirects to the secure link. This must be a post-reply check in the guardrail layer, not only a prompt instruction.
- The agent never states that someone "is verified" or "is approved" unless `get_case_status` returned that state, and never for KYB.
- Evals: at least one case per rule above, in `whatsapp` and `web`, in English and one other market language, using the existing `says_any` / `says_none` eval format.

7.5 Delivery

Packages live in `data/agents/` as `africa-kyc-verifier.agent.json` and `africa-kyb-onboarding.agent.json`, validated by `scripts/marketplace/validate_package.py`, with a build note in `docs/marketplace/matching INSURANCE_OPS_SUITE.md`. Rental follows the existing tier pricing in `agent_platform/config.py`; per-check vendor costs are metered separately by the core and invoiced through the tenant, not the agent rental.

8. Compliance and regulatory requirements

This is not legal advice. It is the list of obligations the product must be built to satisfy, to be confirmed with counsel before the first regulated client.

South Africa (first market)

- **FICA.** Accountable institutions must perform customer due diligence, identify beneficial owners, screen against sanctions lists and keep records for five years. Your clients are the accountable institutions; your product must give them an evidence pack that survives an FIC inspection.
- **Beneficial ownership.** The CIPC register uses a 5% threshold. The threshold must be a per-jurisdiction setting.
- **POPIA.** Biometric data is special personal information (section 26) and requires consent or another authorisation; you need an Information Officer, a lawful-basis record per processing purpose, and a basis for cross-border transfer (section 72) because Didit and most screening vendors process outside South Africa. Data subjects can request access and deletion.
- **Retention and deletion.** Per-tenant policy, enforced by a job, with a deletion record.

Other markets in the current country list

- **Nigeria:** Nigeria Data Protection Act 2023 and CBN KYC tiers; BVN/NIN access is licensed.
- **Kenya:** Data Protection Act 2019, registration as a data processor, IPRS access via licensed partners.
- **Ghana:** Data Protection Act 2012, NIA Ghana Card verification via partners.

- Uganda: Data Protection and Privacy Act 2019; NIRA and URA access via agreements.

Product controls that follow

- Consent capture at the start of every hosted flow, stored as evidence with timestamp, IP and text version.
- Data residency setting per tenant, honoured by object storage region.
- Human decision on every KYB case; system decisions on KYC only where the tenant has opted in and the vendor confidence is above a tenant threshold.
- A DPA (data processing agreement) template and a security overview for client procurement. Zara already has `agent_platform/security_pack.py` ; extend it.
- Independent penetration test before the first external client.

9. Roadmap

Effort is indicative, for one to two engineers, and assumes the rebuild rather than patching. Each phase has exit criteria; a phase is not done until they pass.

PHASE	GOAL	WORK	EXIT CRITERIA
0. Stop the bleeding	Make the current deployment safe to leave running or take it down	Rotate Dedit, Twilio and session secrets. Remove committed tokens and cookies from the repo and its history. Put every write and PII endpoint behind authentication or remove it. Delete the <code>x-demo-mode</code>	No unauthenticated write or PII route (Appendix A all green). No secrets the tree.

PHASE	GOAL	WORK	EXIT CRITERIA
		bypass and the unsigned webhook. Disable the WhatsApp send endpoint. Take <code>ekyc-africa.com</code> off public DNS if no one is using it.	
1. Verification Core, KYC pilot	A hardened, multi-tenant KYC API with real Didit results	New service per Section 6.1. Tenants, API keys, hashed passwords, RBAC. Case model. Didit adapter on the current API with signed, idempotent webhooks. Outbound webhooks. Hosted KYC flow reusing the existing client pages under one brand. WhatsApp link via Twilio. Audit table. Dockerfile, migrations, CI with typecheck, lint, tests and audit.	Two tenants (Gaslit drivers, Zara partners) complete real verifications end to end. Webhook status persists. Zero critical or high audit findings. Test coverage on auth, tenancy isolation and webhook verification.

PHASE	GOAL	WORK	EXIT CRITERIA
2. Real KYB	Honest business verification with human decision	Registry adapter interface with South Africa first and manual-review fallback. Sanctions and PEP screening adapter. UBO discovery with per-jurisdiction threshold. Related-person KYC links. Case review UI for the compliance officer. Evidence pack export (PDF).	A South African company can be onboarded with a registry extract, screened directors and UBOs, and a signed decision. No code path produces a result without a vendor response or a human attestation.
3. Onboarding Flows	Configurable white-label journeys	Flow definitions and runs. Step renderers. Tenant branding. Resumable links. Agreements step with e-signature record. Client dashboard per tenant. Retention jobs and deletion. Consent capture.	A client configures flow without engineering help and receives a webhook on completion. Retention policy demonstrably deletes.
4. Zara marketplace agents	KYC and KYB agents rentable in	MCP server on the core. Two packages, suite	Packages pass <code>validate_package.py</code> and evals. A rented

PHASE	GOAL	WORK	EXIT CRITERIA
	the marketplace	entry, guardrails, evals. Partner console wiring. Metering of per-check vendor costs.	kyc-verifier completes a real verification from WhatsApp in sandbox and live.
5. Trust and scale	Sell to regulated clients	Penetration test and remediation. DPA and security pack. Smile ID adapter for government checks. Second registry country. SOC 2 readiness backlog. Load test.	Pen test report with no open high findings. First external regulated client signed.

Cumulative: a pilot-safe KYC product after Phase 1 (about two months), and a sellable KYC + KYB + onboarding product after Phase 3 (about five months). Phase 4 can run in parallel with Phase 3 once the core API is stable.

10. Definition of production ready

The product is ready to offer to a client when all of the following hold. Use this as the release gate, replacing the current `PRODUCTION-READINESS.md`.

- ☐ Every route is authenticated and scoped to a tenant; an automated test proves tenant A cannot read tenant B.
- ☐ Passwords hashed with argon2; API keys hashed; secrets only from environment; no secrets in git history.

- ☐ Every inbound webhook verified on raw bytes and idempotent; no bypass paths.
- ☐ No code path returns a verification, screening or registry result that did not come from a vendor response or a recorded human attestation. Sandbox results are labelled on every record and every API response.
- ☐ Append-only audit events for every read of PII and every state change, with actor, time and origin.
- ☐ Consent captured and stored per applicant; retention policy enforced by a scheduled job; deletion produces a record.
- ☐ Documents and vendor payloads stored encrypted in region-pinned object storage, never in the database or process memory.
- ☐ CI blocks merge on typecheck, lint, tests and dependency audit (no critical or high).
- ☐ Containerised deployment with migrations, health checks, structured logs, rate limiting and security headers.
- ☐ Independent penetration test with no open high findings.
- ☐ DPA, privacy notice and security overview available for client procurement.
- ☐ Marketing pages describe only what exists.

11. Decisions needed from you

1. **Rebuild or patch.** This document recommends a rebuild of the server with the client largely kept. Patching is possible but would cost about the same and leave the case model and tenancy bolted on.
2. **Brand.** eKYC Africa, SwifterID or a Zara sub-brand. One name across code, domain and marketplace.
3. **First external market and vertical.** South Africa lenders and fintech is the natural fit with FICA and the Zara banking suite. Confirm.
4. **KYB honesty line.** Approve the "assisted KYB with human decision" positioning for Phase 2 rather than promising automated registry checks in countries where API access is not yet contracted.
5. **Vendor contracts.** Approve opening commercial conversations with Didit (production tier), Smile ID and a South African company data partner.

6. **Pilots.** Approve Gaslite driver onboarding and Zara partner onboarding as the two internal pilots.
7. **Where the code lives.** Recommend a fresh `verification-core` repository, with the current `ekyc` repo archived as the prototype reference.

Appendix A: route inventory and authentication state

ROUTE	METHOD	AUTH TODAY	DATA EXP OR CHANGE
<code>/api/auth/login</code> <code>/logout</code> <code>/me</code>	POST/GET	session	credential (plain text comparison)
<code>/api/verification-sessions</code>	POST	admin	creates session
<code>/api/verification-sessions</code>	GET	none	all sessions (masked)
<code>/api/verification-sessions/:id</code>	GET	none	session detail (masked)
<code>/api/verification-sessions/:id</code>	PATCH	none	status, confidence
<code>/api/webhooks/didit</code>	POST	HMAC, bypassable	session status (update no-op)
<code>/api/webhook/didit</code>	POST	none	session status
<code>/api/didit/create-session</code>	POST	none	creates session

ROUTE	METHOD	AUTH TODAY	DATA EXP OR CHANG
/api/didit/console-data/:id /console-sessions /session-status/:id /discover /callback	GET/POST	none	vendor
/api/stats /api/analytics/comprehensive /api/analytics/export	GET	none	aggrega and full export
/api/business-verification/sessions	POST/GET	none	full KYB records UBOs, A
/api/business-verification/sessions/:id	GET/PATCH	none	full reco arbitrar update
/api/business-verification/sessions/:id/complete	POST	none	simulate approve
/api/kyb/uganda/onboard	POST	none	in-mem applicat with ID
/api/kyb/uganda/status/:ref	GET	none	status
/api/kyb/uganda/applications	GET	none	all applicar
/api/kyb/uganda/applications/:id/status	PATCH	none	approve reject
/api/kyb/uganda/validate-tin /validate-nid	POST	none	regex on
/api/whatsapp/create-verification-link	POST	none	sends WhatsA via Twili
/whatsapp-verify/:token /api/whatsapp/verify/:token	GET	token	applicar session

ROUTE	METHOD	AUTH TODAY	DATA EXP OR CHANG
/api/whatsapp/session/:id	GET	none	phone, (user age
/api/maintenance/enable /disable /api/emergency-disable-maintenance	POST/GET	none	mainten flag
/api/test-tokens /create /deactivate /cleanup	GET/POST	none	all test tokens
/attached_assets/* /test-manager.html /admin-maintenance.html /emergency-access.html	GET	none	screens admin p

Appendix B: build and audit output

```

npm run check      13 type errors (client 7, server 6); build script bypasses tsc so t
npm audit --omit=dev
                  36 vulnerabilities: 1 critical (fast-xml-parser), 21 high (incl. ws

tests             none
CI                none
lint              none
migrations        none (drizzle-kit push)
Dockerfile        none

```

Unused production dependencies observed: helmet , cors , express-rate-limit , compression , connect-pg-simple , passport , passport-local , openai , @google-cloud/storage , @uppy/* , @ballerine/web-ui-sdk , twilio (raw fetch is used instead).